

fore protects the encrypted data even when the disk is removed and placed in another system, the system is booted using a different operating system, or the unencrypted files on the boot volume are compromised.

6.3 Code Integrity Verification

Malicious programs (malware) are a common occurrence in the Windows world. There are several established tools which work to identify and root out malware external to the system—such as viruses, worms, Trojans and such. However, there is another form of malware that seeks to undermine and attack a system from within. Such software is generally implemented to run at a kernel level and runs with the same privileges that the kernel enjoys. These are therefore most difficult to identify, isolate and remove.

Vista introduces functionality that aims to separate malware from real applications and device drivers. Through a code integrity initiative, Vista uses certificates to identify and allow digitally signed device drivers to run. This feature—the kernel-mode code signing (KMCS)—only allows device drivers to load if they are published and digitally signed by developers who have been examined by one of a handful of certificate authorities (CAs).

KMCS uses public-key cryptography to implement authoritative certificates for programs and drivers. A software publisher can either get the appropriate certificate from Microsoft itself (though the Windows Hardware Quality Laboratory, WHQL), or they can obtain a certificate from one of the authorities that Microsoft has identified as trusted. The authority then digitally hashes the code, signs the hash by encrypting it with a private key, and includes the certificate and encrypted hash with the code.

When a driver tries to load, Windows decrypts the hash included with the code using the public key stored in the certificate, then ver-